

Votre mission :

Un SI au service de la communauté

SECURISER L'ACCES AUX SERVICES ET AUX DONNEES DU SYSTEME D'INFORMATION

Périmètre : Système d'Information de la mairie de Kernelac

Référentiel de gestion : ANSSI, CNIL & Règlement Général sur la Protection des Données

Statut du document : Document de gouvernance et d'exploitation technique

Auteur : Responsable IT

Date de rédaction : 24 juin 2026

Ce document formalise les piliers de la politique de sécurité des systèmes d'information de la mairie. Il détaille les mesures architecturales et organisationnelles mise en œuvre pour assurer la sécurité du SI de la mairie de Kernelac.

Table des matières

1. Politique de sécurité informatique PSSI et classification des flux 2
1.1. Cartographie et analyse de la sensibilité des flux métiers et IOT 2
1.2. Alignement Volontaire NIS2 : Robustesse face aux crises 2
2. Configuration des composants de sécurité et protection périmétrique 2
2.1. Systèmes de détection et de prévention des intrusions réseau : IDS/IPS 2
2.2. Proxy transparent et obligations de filtrage web sortant 3
2.3. Reverse Proxy : Protection et aiguillage des flux entrants 3
2.4. Sécurité de l'infrastructure physique : Alarme intrusion et contrôle d'accès 3
3. Maintien en condition de sécurité et protection antivirale 3
3.1. Gestion du patching de sécurité et mises à jour du SI : Microsoft Intune 4
3.2. Sécurité des points de terminaison : Microsoft Defender 4
4. Confidentialité, vidéo-sécurité et obligations juridique 4
4.1. Sécurisation des habilitations et droits d'accès 4
4.2. Durcissement de la BDD de l'État Civil 5
4.3. Cadre légal de la Vidéo-sécurité / Vidéo-protection 5
4.3. Contraintes juridiques d'extraction de la preuve numérique 5
4.4. Cadre réglementaire externe : CGU du Wi-Fi GUEST 5
4.5. Cycle de vie des matériels : Traitement des DEEE et destruction des données 6
5. Authentification et non-répudiation des utilisateurs 6
5.1. Sécurisation de l'annuaire 6
5.2. Contrôle d'accès réseau 6
5.3. Double Facteur d'Authentification (MFA) 7

La refonte globale de l'infrastructure numérique de la Mairie de Kernelac et l'interconnexion de ses différents pôles administratifs imposent une vision transversale de la cybersécurité. Une Politique de Sécurité des Systèmes d'Information moderne doit impérativement intégrer la sécurité physique des locaux. Une faille d'accès matériel au sein de la baie informatique ou des bureaux de l'Hôtel de Ville annulerait instantanément l'efficacité des barrières logiques les plus avancées.

En tant qu'administration publique gérant des données à caractère personnel de souveraineté et des infrastructures critiques, la mairie est soumise à un double faisceau de contraintes : le respect strict du RGPD pour les données des administrés et des agents, et la conformité avec le Code de la Sécurité Intérieure concernant les dispositifs de surveillance publique.

1. Politique de sécurité informatique PSSI et classification des flux

La PSSI de la collectivité traduit les obligations légales de sécurité en règles d'ingénierie. Elle s'appuie sur une cartographie des flux permettant d'appliquer des traitements différenciés selon les risques d'exposition pénale ou de rupture de service public.

1.1. Cartographie et analyse de la sensibilité des flux métiers et IOT

ID	Nature	Rôle	Type de données	Cadre réglementaire	Niveau criticité	Traitement de sécurité
FLX-01	Flux d'identité AD	Réplication and authentification entre SRV-MAI-AD-001 et 002	Mots de passe chiffrés Jetons Kerberos GPO	Secret professionnel Art. 226-13 du Code Pénal	Critique	Isolation stricte dans le VLAN 20 Interdiction des protocoles d'administration clairs
FLX-02	Requêtes BDD	Échanges applicatifs avec le serveur de base de données SRV-MAI-BDD-001 et 002	Identités des administrés État Civil Finances municipales	Obligation de sécurité RGPD Art. 32 du RGPD	Très élevé	Chiffrement obligatoire des flux via TLS Interdiction du HTTP Comptes de services restreints
FLX-03	Flux vidéo-sécurité IP	Transport des images des caméras vers le stockeur numérique	Flux vidéo temps réel Images de surveillance	Protection de la vie privée CNIL / Code de la Sécurité Intérieure	Elevé	Enclavement total dans le VLAN dédié (Dédié aux caméras/alarmes) Interdiction d'accès au LAN de production
FLX-04	Télémétrie alarmes	Remontée des alertes d'intrusion physique and d'incendie.	Signaux de sabotage Etats des capteurs Logs d'accès physiques	Sécurité des biens et personnes	Elevé	Flux permanent encapsulé and priorisé Tunnelisé de manière sécurisée vers le centre de télésurveillance
FLX-05	Flux de traçabilité	Centralisation des logs d'événements vers SRV-MAI-RSYSLOG-01	Traces d'accès Connexions pare-feu, Modifications système	Preuve juridique légale Loi LCEN / RGS	Moyen	Flux permanent encapsulé en TCP vers un espace de stockage immuable non modifiable

1.2. Alignement volontaire NIS2 : Robustesse face aux crises

La DSI applique un alignement volontaire sur la directive européenne NIS2. Cet engagement renforce la responsabilité de la Direction Générale des Services dans la gestion des cyber-risques et formalise la sécurisation de la chaîne d'approvisionnement : tout accès de maintenance externe est sujet à un filtrage par adresse IP source, à l'obligation d'un tunnel VPN et à une validation par MFA.

2. Configuration des composants de sécurité et protection périmétrique

Les impératifs légaux de protection contre le sabotage et l'exfiltration de données imposent le déploiement d'outils de sécurité active au périmètre du réseau, complétés par une surveillance physique rigoureuse.

2.1. Systèmes de détection et de prévention des intrusions réseau : IDS/IPS

Le cluster de pare-feux de nouvelle génération FortiGate 80F fait office de barrière de filtrage et de surveillance. Des sondes IPS d'analyse comportementale et protocolaire protègent les sous-réseaux :

- **Prévention active :** Le pare-feu bloque instantanément les signatures d'attaques connues ciblant les environnements d'infrastructure de la mairie (vulnérabilités Windows, Debian, tentatives d'injection SQL sur la BDD).

- **Obligation d'étanchéité :** Pour empêcher un attaquant ayant compromis un poste client de rebondir sur le réseau, le pare-feu interdit par défaut tout flux inter-VLAN. Chaque changement de zone réseau subit une analyse applicative.

2.2. Proxy transparent et obligations de filtrage web sortant

La protection des 104 agents contre les menaces externes (phishing, rançongiciels, contenu illicite) s'appuie sur un mode proxy transparent :

- **Analyse SNI :** Le pare-feu intercepte le trafic web des utilisateurs et analyse l'en-tête Server Name Indication du protocole TLS pour identifier le domaine distant visé, sans rompre la confidentialité du contenu des communications des agents
- **Moteur FortiGuard :** Les requêtes sont filtrées en temps réel. L'accès aux sites de piratage, botnets, ou malwares est bloqué. Par ailleurs, pour respecter la charte informatique de la collectivité et préserver la bande passante publique, l'accès aux catégories non professionnelles (jeux d'argent, pornographie, streaming de masse) est automatiquement rejeté

2.3. Reverse Proxy : Protection et aiguillage des flux entrants

À l'inverse du proxy classique, le Reverse Proxy est un bouclier mis en place pour protéger les serveurs internes de la mairie des connexions provenant de l'extérieur (ex : accès à la gestion de parc GLPI par des techniciens distants ou accès à l'Intranet). Lorsqu'une requête externe arrive sur l'adresse publique de la mairie, elle frappe exclusivement le Reverse Proxy. Celui-ci gère le chiffrement HTTPS global, puis la redirige en HTTP local vers le serveur cible. Ce composant garantit deux objectifs :

1. **Masquage d'architecture :** L'adresse IP réelle des serveurs reste totalement invisible pour le monde extérieur. Seule l'IP du Reverse Proxy est exposée
2. **Centralisation de la sécurité HTTP :** C'est à cet endroit unique que sont injectés les en-têtes de sécurité HTTP stricts empêchant les attaques de type Clickjacking ou injection de contenu

2.4. Sécurité de l'infrastructure physique : Alarme intrusion et contrôle d'accès

La sécurité logique dépend directement de la sanctuarisation de la baie informatique principale. Pour s'assurer qu'aucun individu non autorisé ne puisse se connecter physiquement aux commutateurs ou aux hyperviseurs Lenovo, la mairie déploie un système d'alarme et de contrôle d'accès dédié :

- **Centrale d'alarme intrusion :** La salle des serveurs et les bureaux de l'Hôtel de Ville sont protégés par des détecteurs de mouvement et des contacts d'ouverture de porte magnétiques. La centrale d'alarme est raccordée au réseau chiffré de la mairie, doublée d'un émetteur cellulaire 5G indépendant. En cas d'intrusion détectée, l'alerte de sabotage ou d'intrusion est immédiatement transmise au centre de télésurveillance
- **Contrôle d'accès par badges :** L'accès à la salle technique est verrouillé par une gâche électromagnétique pilotée par un lecteur de badges. Chaque badge est nominatif et associé à un profil horaire strict dans l'application d'administration. Les tentatives d'ouverture infructueuses ou les ouvertures prolongées déclenchent une alerte technique immédiate. Tout événement d'accès physique génère un log immuable déporté sur le serveur de supervision

3. Maintien en condition de sécurité et protection antivirale

L'application de l'article 32 du RGPD concernant la sécurité et la résilience des traitements impose d'éradiquer proactivement les vulnérabilités logicielles et de bloquer l'exécution de charges virales au niveau des terminaux.

3.1. Gestion du patching de sécurité et mises à jour du SI : Microsoft Intune

L'ANSSI rappelle que le retard dans l'application des correctifs de sécurité constitue le premier vecteur d'intrusion au sein des collectivités. Pour y remédier, la mairie a banni les serveurs de mise à jour locaux au profit d'une gouvernance cloud centralisée :

- **Automatisation via Microsoft Intune :** Le MCS des 106 terminaux est piloté par des profils d'anneaux de mise à jour. Les patchs critiques de qualité et de sécurité du *Patch Tuesday* sont appliqués de manière asynchrone.
- **Contrainte d'installation et de redémarrage** : Afin de concilier les impératifs de sécurité et continuité de la productivité administrative, les politiques Intune interdisent les redémarrages intempestifs durant les heures de production. Les installations forcées et les redémarrages de conformité sont planifiés exclusivement sur la pause méridienne, entre 12h15 et 13h30 et de 20h à 00h
- **Mises à jour de l'infrastructure virtuelle :** Les 18 machines virtuelles s'exécutant sur le cluster VMware ESXi font l'objet d'une politique de patching mensuelle planifiée durant la fenêtre de maintenance curative définie dans les accords de niveau de service de la collectivité.

3.2. Sécurité des points de terminaison : Microsoft Defender

L'usage d'un antivirus traditionnel basé uniquement sur des bases de signatures de fichiers est obsolète face aux attaques modernes par rançongiciel. La mairie déploie une solution de détection et de remédiation avancée sur les points de terminaison :

- **Analyse comportementale :** L'agent Microsoft Defender for Endpoint surveille en continu les processus actifs, les appels système et les modifications de la base de registre sur l'ensemble des postes clients. Il est capable de détecter les comportements suspects, tels que le chiffrement rapide et massif de fichiers
- **Règle d'anti-altération :** Pour empêcher un logiciel malveillant ou un utilisateur mal intentionné de désactiver les barrières de sécurité, la fonction de protection anti-altération est verrouillée par Intune. Les services de l'EDR ne peuvent être arrêtés, même avec des privilèges d'administrateur local
- **Playbook de remédiation et isolation logique :** En cas d'alerte de sévérité haute, l'EDR bloque immédiatement le processus malveillant et place le fichier en quarantaine. L'administrateur applique instantanément la directive d'urgence consistant à isoler logiquement la machine depuis la console cloud. Le terminal est coupé de tout échange avec la zone serveurs et les partages DFS, neutralisant le risque de propagation latérale, tout en conservant son lien avec la console de sécurité pour permettre l'analyse et la désinfection à distance

4. Confidentialité, vidéo-sécurité et obligations juridique

Ce chapitre traite du respect du cadre juridique français et européen en matière de protection des données, de vidéo-sécurité, de conservation des preuves et de gestion des équipements informatiques.

4.1. Sécurisation des habilitations et droits d'accès

Le RGPD impose à la mairie de mettre en œuvre des mesures techniques garantissant que seuls les agents ayant un besoin métier légitime accèdent aux données des citoyens :

- **Méthodologie AGDLP :** Les autorisons sur les dossiers partagés de la racine DFS éliminent tout droit individuel. Les privilèges sont gouvernés par des groupes de sécurité imbriqués dans Active Directory.

- **Cloisonnement NTFS strict :** Les répertoires sensibles font l'objet d'une rupture d'héritage explicite. Un agent affecté au pôle technique ou scolaire n'a techniquement aucun moyen d'accéder aux données RH, prévenant toute fuite interne.

4.2. Durcissement de la BDD de l'État Civil

Conformément aux recommandations de la CNIL pour la sécurisation des bases de données administratives, le serveur SRV-MAI-BDD-001 et 002 subissent un durcissement logiciel strict :

- Suppression systématique des comptes d'accès anonymes et des bases de test installés d'usine
- Interdiction absolue pour le compte root de se connecter à distance
- Création de comptes de services dédiés et restreints pour chaque progiciel de la mairie, empêchant une faille applicative de compromettre l'intégralité du système de bases de données

4.3. Cadre légal de la Vidéo-sécurité / Vidéo-protection

Le déploiement des caméras IP au sein de la mairie et de la médiathèque est régi par des contraintes juridiques strictes sous le contrôle de la CNIL et de la préfecture :

- **Raison d'être et proportionnalité :** Le système a pour but exclusif de sécuriser les biens publics, de prévenir les actes de vandalisme et de protéger les agents d'accueil face aux agressions. Les caméras filmant la voie publique font l'objet d'une autorisation préfectorale spécifique, et les zones de travail des agents ne sont pas filmées de manière permanente : respect du droit à la vie privée des employés. Un affichage public réglementaire via panneaux d'information avec pictogramme de caméra informe obligatoirement les citoyens à chaque entrée de bâtiment
- **Durée de rétention légale des images :** Conformément aux exigences de la CNIL, les images enregistrées sur le stockeur vidéo de la mairie sont conservées pendant une durée maximale de 30 jours. À l'issue de ce délai, un mécanisme automatisé écrase de manière irréversible les données les plus anciennes
- **Enclavement réseau et risque pivot :** Les caméras IP étant des cibles privilégiées pour les cyberattaques, elles sont isolées au sein du VLAN IOT. Le FortiGate 80F interdit de manière absolue tout flux initié depuis le VLAN IOT vers le réseau de production des agents ou des serveurs, empêchant un attaquant ayant pris le contrôle d'une caméra physique de rebondir sur le cœur du SI

4.3. Contraintes juridiques d'extraction de la preuve numérique

La Mairie de Kernelac est soumise à des contraintes impératives de traçabilité, tant pour ses logs réseau que pour ses enregistrements vidéo :

- **Rétention des logs :** L'historique de l'entièreté des logs d'activité du SI sont conservés pendant 1 an sur le serveur RSYSLOG
- **Traitement des réquisitions juridiques :** En cas d'infraction, de cambriolage ou d'enquête pénale, les enregistrements vidéo et les logs système ne peuvent être consultés que par les personnes expressément habilitées par arrêté du Mairie. L'extraction définitive des données numériques est subordonnée à la présentation d'une réquisition juridique officielle signée par un Officier de Police Judiciaire ou un juge d'instruction. Les fichiers extraits sont accompagnés d'une empreinte cryptographique (hash MD5/SHA256) pour garantir leur intégrité et leur validité juridique devant les tribunaux (non-répudiation).

4.4. Cadre réglementaire externe : CGU du Wi-Fi GUEST

La mise à disposition d'un réseau Wi-Fi gratuit au public au sein de l'Hôtel de Ville et de la Médiathèque qualifie juridiquement la mairie comme un FAI opérationnel. À ce titre, la collectivité s'astreint à des règles très strictes :

- **Portail captif et CGU :** L'authentification des usagers exige l'acceptation obligatoire de Conditions Générales d'Utilisation. Ces CGU dégagent la responsabilité de la mairie en cas d'activité illégale ou de cybercriminalité commise par un citoyen, reportant la responsabilité pénale sur l'usager

- **Séparation étanche et rétention :** Les logs de navigation des citoyens sont strictement isolés de la production interne. Le proxy enregistre l'adresse MAC du terminal, la date/heure de session et les protocoles utilisés, mais interdit formellement l'enregistrement du contenu des messages, préservant ainsi le secret constitutionnel des correspondances privées

4.5. Cycle de vie des matériels : Traitement des DEEE et destruction des données

Le cycle de vie des matériels informatiques de la mairie constitue une contrainte réglementaire majeure combinant la Loi REEN visant à la réduction de l'empreinte environnementale et le RGPD visant la sécurité des données au rebut. Un disque dur jeté ou recyclé sans décontamination complète expose la mairie à des sanctions lourdes pour violation de données.

La DSI applique strictement le protocole suivant lors du déclassement des matériels :

- **Support fonctionnel :** Tout matériel informatique possédant une mémoire ou un système de stockage sortant du parc de la mairie pour être reconditionné fait l'objet d'un effacement logique durci. Le service informatique procède à un reformatage bas niveau via une méthode d'écriture à passes multiples, rendant impossible toute reconstruction logicielle des anciennes données métiers

- **Support hors-service :** Si un disque dur ou un support de stockage flash est techniquement défectueux, le service informatique réalise une destruction physique au sein des ateliers municipaux. Le composant subit une perforation mécanique ou une démagnétisation lourde, détruisant physiquement les plateaux magnétiques ou les puces de mémoire

- **Traçabilité et certification :** Pour chaque composant détruit ou recyclé, un Certificat de Destruction de Données est exigé et consigné au sein de l'inventaire centralisé GLPI. Les matériels ainsi décontaminés sont ensuite confiés à un éco-organisme agréé pour le traitement des DEEE, garantissant la conformité environnementale et la sécurité juridique de la collectivité

5. Authentification et non-répudiation des utilisateurs

L'accès aux ressources numériques de la commune impose l'identification certaine de l'utilisateur afin de garantir la traçabilité complète des actions menées sur le réseau.

5.1. Sécurisation de l'annuaire

L'infrastructure d'identité s'appuie sur le protocole Kerberos et l'annuaire Active Directory sous Windows Server 2025.

- Afin de se conformer au Référentiel Général de Sécurité de l'ANSSI, le protocole LDAP classique (Port TCP 389) qui fait circuler les requêtes en clair sur le réseau local est banni

- Toutes les authentifications sont chiffrées via le protocole LDAPS (LDAP over SSL- Port TCP 636). Ce tunnel sécurisé s'appuie sur des certificats numériques émis par le serveur d'autorité de certification interne de la mairie

5.2. Contrôle d'accès réseau

Pour interdire l'introduction d'un équipement pirate ou inconnu dans les prises murales ou sur le réseau Wi-Fi de la mairie, le contrôle d'accès s'appuie sur la norme 802.1X :

- Le terminal doit s'authentifier auprès du commutateur Cisco ou de la borne Wi-Fi d'entreprise avant d'obtenir une adresse IP
- L'équipement réseau relaye cette demande d'accès au serveur RADIUS centralisé sur le serveur dédié
- Le serveur RADIUS valide la présence du certificat machine délivré par l'infrastructure de clés publiques de la mairie et contrôle l'appartenance de l'agent à l'annuaire. Si le contrôle réussit, le port s'ouvre sur le VLAN correspondant. Dans le cas contraire, le poste est immédiatement rejeté ou isolé sur un VLAN de quarantaine sans aucun accès aux serveurs métiers

5.3. Double Facteur d'Authentification

L'accès au Système d'Information depuis l'extérieur (ex : télétravail des cadres de la mairie, interventions techniques de télémaintenance de l'infogérant) représente un risque élevé d'usurpation d'identité par vol de mot de passe.

Pour garantir une non-répudiation absolue, le pare-feu FortiGate 80F impose une authentification forte multi-facteur :

1. **Premier facteur :** Saisie des identifiants nominatifs Active Directory complexes.
2. **Second facteur :** Validation d'une notification push ou saisie d'un code de sécurité à usage unique généré en temps réel sur l'application sécurisée FortiToken installée exclusivement sur le smartphone professionnel validé de l'agent ou du technicien externe

6. Conclusion

Par l'articulation de ces mesures, la mairie de Kernelac dispose d'une architecture de sécurité cohérente, résiliente et parfaitement alignée sur les cadres légaux en vigueur. En unifiant la protection logique périmétrique avec le maintien en condition de sécurité et la surveillance physique des infrastructures la collectivité assure la continuité du service public tout en protégeant juridiquement la responsabilité du Maire et de ses administrés.

Liberté • Égalité • Fraternité
RÉPUBLIQUE FRANÇAISE

Direction Générale des Services

Mairie de Kernelac

Gouvernance des Systèmes d'Information

Tél : 01.00.32.23.01

Courriel : mairie@kernelac.fr

Kernelac, le **24 JUIN 2026**

CHARTE D'UTILISATION DES MOYENS INFORMATIQUES ET NUMERIQUES

Règlement intérieur relatif à la sécurité logique et physique du Système d'Information

PREAMBULE

Le Système d'Information de la Mairie de Kernelac constitue un outil de travail indispensable à l'accomplissement des missions de service public de la collectivité. L'ouverture du réseau vers des usages nomades, l'interconnexion des pôles distants et la sophistication croissante des cybermenaces imposent de définir des règles strictes d'utilisation et d'hygiène informatique.

La présente charte a pour but de sensibiliser les utilisateurs aux risques cyber, de sanctuariser la protection des données à caractère personnel des administrés et des agents conformément au RGPD, et de fixer les obligations légales de traçabilité requises par les autorités judiciaires. La DSI applique une démarche exemplaire d'alignement volontaire sur la directive européenne NIS2 pour garantir la résilience et la continuité des infrastructures municipales.

ARTICLE 1 : CHAMP D'APPLICATION ET OPPOSABILITE

1.1. Personnes concernées : La présente charte s'applique de manière obligatoire à l'ensemble des agents municipaux titulaires, contractuels et stagiaires de la commune, répartis entre l'Hôtel de Ville et ses pôles raccordés.

1.2. Intervenants externes : Les dispositions de la charte s'étendent également aux tiers autorisés, stagiaires, élus, ainsi qu'aux techniciens du prestataire d'infogérance externe disposant d'un droit d'accès temporaire ou permanent aux infrastructures de la mairie.

1.3. Valeur juridique : Ce document constitue un avenant au règlement intérieur de la Mairie de Kernelac. Il est opposable à chaque utilisateur dès sa notification ou signature, et sa violation expose son auteur à des sanctions administratives, disciplinaires ou pénales.

ARTICLE 2 : ACCES AUX EQUIPEMENTS ET AUTHENTIFICATION

2.1. Identifiants nominatifs : Chaque agent se voit attribuer un compte d'accès unique et nominatif au sein de l'annuaire centralisé Active Directory. L'utilisation d'un identifiant et d'un mot de passe est strictement personnelle et intransmissible. Le prêt de session ou le partage de mots de passe entre collègues est formellement interdit.

2.2. Robustesse des secrets : Les mots de passe d'accès au domaine doivent respecter la politique de complexité imposée par la DSI (longueur minimale, caractères alphanumériques et spéciaux). Ils ne doivent jamais être consignés sur un support physique ou stockés en clair.

2.3. Double Facteur d'Authentification : Tout accès distant au réseau de la mairie est assujetti à la validation d'un second facteur d'authentification dynamique via l'application FortiToken sur smartphone professionnel. L'agent s'engage à refuser immédiatement toute notification push MFA dont il n'est pas l'initiateur et à alerter l'équipe informatique.

2.4. Verrouillage de session : Afin de garantir la non-répudiation, l'utilisateur a l'obligation de verrouiller manuellement sa session : raccourci clavier « Touche Windows + L » lors de tout éloignement de son poste de travail, même pour une courte durée. En complément, une stratégie automatisée verrouille l'écran après 10 minutes d'inactivité.

ARTICLE 3 : UTILISATION DES MOYENS DE COMMUNICATION ET INTERNET

3.1. Usage professionnel prioritaire : Les accès Internet et les terminaux utilisateurs mis à disposition par la mairie sont réservés à un usage exclusivement professionnel lié aux compétences de l'agent. Un usage privé résiduel et raisonnable est toléré sur les temps de pause, à condition qu'il n'entrave pas la productivité du service et ne compromette pas la sécurité du réseau.

3.2. Dispositif de filtrage : La navigation internet sortante fait l'objet d'une interception et d'un filtrage automatisés par le cluster de pare-feux. Sont bloqués de plein droit :

- Les catégories de menaces cyber avérées (sites de phishing, serveurs de commande de malwares, botnets, etc.).
- Les contenus contraires aux missions de service public et à l'éthique de la collectivité (jeux d'argent, pornographie, sites haineux, téléchargement illégal ou Peer-to-Peer, etc.).

3.3. Interdiction de contournement : Toute tentative de contournement des mécanismes de sécurité périmétriques (utilisation de proxys externes, de VPN anonymisateurs tiers ou de partages de connexion mobiles non approuvés sur les machines de la mairie) constitue une faute grave.

ARTICLE 4 : MESSAGERIE ELECTRONIQUE ET OUTILS COLLABORATIFS

4.1. Utilisation de la boîte officielle : L'adresse électronique nominative fournie par la mairie est le canal officiel et unique pour toute correspondance administrative ou technique liée à la commune. L'usage des messageries personnelles pour traiter des dossiers de la mairie est formellement interdit afin d'éviter la fuite de données d'administrés.

4.2. Vigilance face aux attaques par hameçonnage : L'agent doit faire preuve d'une vigilance constante lors de la réception de courriels externes. En cas de doute sur l'identité de l'expéditeur, la présence d'une pièce jointe suspecte ou d'un lien incitant à la saisie d'identifiants, l'utilisateur ne doit pas cliquer et doit immédiatement notifier la DSI via la création d'un ticket sur la plateforme d'assistance GLPI.

4.3. Stockage et outils collaboratifs : Le partage et le stockage de documents professionnels s'exécutent au sein de l'infrastructure de fichiers de la mairie ou des espaces cloud managés (SharePoint ou Teams). Le téléversement de documents contenant des données de la mairie sur des stockages en ligne personnels est interdit.

ARTICLE 5 : SECURITE ACTIVE, INTEGRITE DU SI ET LOGICIELS TIERS

5.1. Sanctuarisation des configurations : L'installation de logiciels, d'applications, d'extensions de navigateurs ou la modification des paramètres réseau et système sur les ordinateurs sont de la compétence exclusive de l'équipe informatique interne et de l'infogérant Volteia Systems. Les agents ont interdiction de télécharger et d'exécuter des binaires ou outils non approuvés.

5.2. Supervision comportementale : L'ensemble de la flotte cliente est placé sous la surveillance continue de la solution de détection et de remédiation avancée Microsoft Defender for Endpoint. Cet agent EDR analyse l'activité du système pour neutraliser en temps réel les comportements malveillants.

5.3. Protection anti-altération : Les mécanismes de protection locale de l'EDR et du pare-feu Windows Defender sont verrouillés de manière centralisée. L'agent ne doit en aucun cas tenter de désactiver, modifier ou suspendre l'activité de l'antivirus.

5.4. Playbook d'urgence et isolation d'hôte : L'utilisateur est informé qu'en cas de détection d'un signal faible d'infection critique, l'équipe informatique déclenchera à distance l'isolation logique immédiate de la machine. Le poste sera instantanément coupé de tout échange avec la zone serveurs et le réseau DFS pour empêcher la propagation latérale, tout en restant connecté à la console cyber pour désinfection.

ARTICLE 6 : PROTECTION DES DONNEES À CARACTERE PERSONNEL ET SECRET PROFESSIONNEL

6.1. Conformité RGPD (Art. 32) : Dans le cadre de leurs fonctions, les agents de la mairie collectent, consultent et traitent des données à caractère personnel relatives aux administrés (État Civil, fichiers scolaires, listes électorales, urbanisme, données financières). L'accès à ces informations est soumis à une obligation stricte de confidentialité.

6.2. Cloisonnement et besoin d'en connaître : Les privilèges d'accès aux dossiers partagés sont segmentés par services via l'Active Directory. Un agent n'est autorisé à consulter que les données strictement nécessaires à l'accomplissement de sa mission métier. Toute consultation de fichiers par curiosité, opportunisme ou en dehors du cadre strict des attributions de l'agent constitue un détournement de finalité réprimé par la loi.

6.3. Secret professionnel : Conformément à l'article 226-13 du Code Pénal, les agents sont tenus au secret professionnel. Il est interdit de divulguer, d'exporter ou de transmettre à des tiers non autorisés des informations nominatives ou confidentielles issues des bases de données de la mairie.

ARTICLE 7 : TRACABILITE, JOURNALISATION TECHNIQUE ET VIE PRIVEE

7.1. Obligations légales de rétention : Pour répondre aux contraintes légales et permettre le traitement d'éventuelles réquisitions judiciaires, la Mairie de Kernelac enregistre et centralise en temps réel l'ensemble des traces d'accès réseau et de navigation internet. Ces journaux techniques sont expédiés vers le serveur de logs et conservés pendant une durée réglementaire de 365 jours avant purge automatique.

7.2. Traitement des réquisitions : En cas d'infraction pénale ou d'enquête, ces logs seront extraits et remis officiellement aux Officiers de Police Judiciaire sur présentation d'un titre exécutoire, engageant la traçabilité complète de l'activité de la session de l'agent.

7.3. Respect de la vie privée au travail : Soucieuse de respecter la vie privée de son personnel, l'administration met à disposition de chaque agent un espace disque individuel de 5 Go sur le réseau DFS. Les fichiers et courriels explicitement identifiés par la mention « PRIVÉ » ou « PERSONNEL » dans leur objet ou le nom de leur répertoire de stockage sont protégés par le secret constitutionnel des correspondances. L'administration s'interdit d'en prendre connaissance en dehors des cas exceptionnels prévus par la loi (procédure judiciaire contradictoire ou risque de sécurité imminent pour la collectivité).

ARTICLE 8 : CYCLE DE VIE DES MATEIELS, TRAITEMENT DES DEEE ET DECONTAMINATION DES SUPPORTS

8.1. Cadre éco-responsable et cyber : La gestion du renouvellement du parc informatique et le déclassement des déchets d'équipements électriques et électroniques de la commune intègrent une obligation stricte de décontamination des données. Aucun support de stockage ne peut quitter physiquement la mairie sans une neutralisation définitive des données qu'il contient.

8.2. Protocole d'effacement logique : Tout support de stockage réformé mais en état de marche destiné au reconditionnement ou au don fait l'objet d'un effacement logique bas niveau durci. Ce processus exécute des passes d'écriture multiples pour interdire toute possibilité de reconstruction ultérieure des fichiers de l'État Civil, des RH ou des administrés.

8.3. Protocole de destruction physique : Si un support de stockage est techniquement défaillant et ne permet pas l'application du reformatage bas niveau, il subit une destruction physique irréversible au sein des ateliers de la mairie, détruisant définitivement les puces de mémoire ou les plateaux magnétiques.

8.4. Traçabilité GLPI : Chaque opération de décontamination ou de destruction donne lieu à l'émission d'un Certificat de Destruction de Données annexé à la fiche de l'actif au sein du gestionnaire de parc GLPI, garantissant la conformité juridique de la mairie lors des audits CNIL.

ARTICLE 9 : MANQUEMENTS ET SANCTIONS

Le non-respect des règles, obligations et interdictions édictées dans la présente charte est susceptible d'engager la responsabilité de l'utilisateur et peut donner lieu à :

1. **Mesures conservatoires techniques :** Une coupure immédiate ou une restriction temporaire des accès de l'agent au domaine kernelac.local et aux outils numériques de la mairie par la DSI pour protéger l'intégrité du réseau.
2. **Sanctions disciplinaires :** Des sanctions administratives prévues par le statut de la Fonction Publique Territoriale allant de l'avertissement, du blâme, jusqu'à la mise à pied temporaire ou la révocation définitive, proportionnelles à la gravité et à la récurrence du manquement constaté.
3. **Poursuites pénales :** Des poursuites pénales engagées par la collectivité ou par des tiers en cas d'infraction caractérisée au Code Pénal (Art. 323-1 et suivants concernant les atteintes frauduleuses à un système de traitement automatisé de données ; Art. 226-13 concernant la violation du secret professionnel).

CADRE D'ENGAGEMENT ET DE SIGNATURE

Je soussigné(e) ……certifie avoir pris connaissance de la présente Charte Informatique et Numérique de la Mairie de Kernelac, en comprendre l'ensemble des dispositions, droits et obligations, et m'engage à m'y conformer scrupuleusement dans l'exercice de mes fonctions de gestion publique.

Lu et approuvé le …….. à …….

Liberté • Égalité • Fraternité
RÉPUBLIQUE FRANÇAISE

Direction Générale des Services

Mairie de Kernelac

Gouvernance des Systèmes d'Information

Tél : 01.00.32.23.01

Courriel : mairie@kernelac.fr

Kernelac, le **24 JUIN 2026**

POLITIQUE DE CONFIRMITE RGPD ET REGISTRE DES TRAITEMENTS

Document réglementaire de gouvernance des données appliqué au Système d'Information

PREAMBULE

Le Règlement Général sur la Protection des Données (RGPD n° 2016/679) et la loi nationale « Informatique et Libertés » modifiée imposent aux collectivités territoriales de garantir un niveau de sécurité et de confidentialité absolue lors du traitement des données à caractère personnel.

Conformément à l'Article 32 du RGPD, le présent document fixe la Politique de Conformité de la mairie. Il recense les verrous logiques, physiques et déployés par la DSI pour éradiquer les vulnérabilités, parer toute tentative d'exfiltration de données, et offrir aux citoyens un cadre de confiance numérique irréprochable.

1. Engagement de la collectivité et politique générale

La Mairie de Kernelac, en tant qu'administration publique territoriale, traite quotidiennement des données à caractère personnel pour mener à bien ses missions de service public au bénéfice des administrés. La refonte et la globalisation de l'infrastructure technique exigent d'instaurer une gouvernance rigoureuse des flux afin de garantir les principes fondamentaux dictés par le RGPD

Ce référentiel formalise l'ensemble des mesures appliquées pour sanctuariser les données des citoyens et des agents. Il constitue l'extrait du registre officiel communal, centré sur le périmètre de responsabilité de la DSI.

2. Registre des activités de traitement

Conformément à l'article 30 du RGPD, la mairie consigne dans son registre interne les fiches des applications manipulant des informations privées. Les traitements rattachés directement à notre infrastructure réseau sont les suivants :

Traitement : Fichier de l'Etat Civil et Affaires Générales

- Finalité : Enregistrement des actes de naissance, mariage et décès ; instruction des demandes de livrets de famille, recensement citoyen et délivrance des titres d'identité nationaux (cartes d'identité, passeports).
- Données traitées : Noms, prénoms, dates et lieux de naissance, filiations complètes, adresses postales, situations de famille, numéros de dossiers ANTS.
- Personnes concernées : Administrés et citoyens de la commune de Kernelac.
- Hébergement technique : Base de données relationnelle centralisée
- Durée de conservation : Conservation permanente pour les registres d'actes d'état civil (directives des Archives de France).

Traitement : Gestion des ressources humaines et de paie

- Finalité : Gestion administrative des carrières, établissement des contrats de travail, édition des bulletins de salaire, suivi des congés/absences et déclarations d'URSSAF.
- Données traitées : Identités, numéros de sécurité sociale, relevés d'identité bancaire, diplômes, évaluations annuelles, coordonnées d'assurance mutuelle.
- Personnes concernées : Les agents municipaux (titulaires, contractuels et stagiaires).
- Hébergement technique : Volume de stockage chiffré et isolé sur le serveur de fichiers centralisé SRV-MAI-DFS-01.
- Durée de conservation : 5 ans à compter du départ de l'agent de la collectivité.

Traitement : Inscriptions aux services scolaires et périscolaires

- Finalité : Inscription des enfants au sein des écoles publiques de la commune, gestion de la restauration scolaire, suivi des activités de loisirs périscolaires et facturation aux familles.
- Données traitées : Identités des mineurs et de leurs représentants légaux, justificatifs de domicile, quotients familiaux CAF, fiches sanitaires de liaison, allergies ou régimes de santé, coordonnées d'urgence.
- Personnes concernées : Élèves scolarisés sur la commune et leurs tuteurs légaux.
- Hébergement technique : Machine virtuelle applicative métier dédiée raccordée au stockage centralisé DFS.
- Durée de conservation : Durée de la scolarité de l'enfant au sein de la commune, augmentée d'un an pour clôture budgétaire.

Traitement : Dispositif de vidéo-protection urbaine et des bâtiments

- Finalité : Assurer la sécurité des biens et des personnes, prévenir les actes de vandalisme sur les bâtiments publics et protéger les agents d'accueil face aux incivilités.
- Données traitées : Enregistrements d'images vidéo horodatées, visages des passants et usagers, plaques d'immatriculation des véhicules circulant ou stationnant aux abords directs des sites équipés.
- Personnes concernées : Usagers des services publics, visiteurs, passants sur la voie publique et personnel municipal.

- Hébergement technique : Enclavement total. Flux vidéo stockés sur un enregistreur numérique physique scellé dans la baie informatique de la mairie.
- Durée de conservation : 30 jours au maximum (Réglementation CNIL & Code de la Sécurité Intérieure). Au-delà, les données sont écrasées automatiquement par le système.

3. Propriétés de sécurité techniques et organisationnelles : Article 32 du RGPD

L'application de l'article 32 du RGPD impose à la mairie de mettre en œuvre des mesures techniques appropriées afin de garantir un niveau de sécurité adapté aux risques d'accès illicites ou de destruction accidentelle des données des citoyens.

Gestion rigoureuse des privilèges

Pour respecter le principe du moindre privilège (*Privacy by Default*), l'attribution de droits nominatifs directs sur le serveur de fichiers SRV-MAI-DFS-01 est proscrite. L'administration s'appuie sur la méthode AGDLP : les permissions NTFS sur les dossiers sensibles (RH, Finances, État Civil) font l'objet d'une rupture d'héritage explicite. Les accès sont délégués uniquement à des groupes de sécurité Active Directory globaux métiers, interdisant de fait à un agent technique ou scolaire d'accéder aux fiches de paie ou aux actes d'état civil d'un tiers.

Sécurisation logicielle et chiffrement mobile

- Chiffrement des terminaux : L'intégralité des ordinateurs attribués aux agents fait l'objet d'un chiffrement complet de disque via Windows BitLocker (AES-XTS 256 bits) managé par Intune. En cas de perte ou de vol d'un appareil lors d'un déplacement d'agent, les données des administrés stockées en cache local restent cryptographiquement inviolables.
- Verrouillage automatique : Une stratégie de conformité globale impose le verrouillage automatique de la session de l'agent après 10 minutes d'inactivité, empêchant toute consultation non autorisée des dossiers en l'absence de l'employé à son bureau.

Détection active des menaces et isolation

Le parc informatique bénéficie de la protection de l'EDR Microsoft Defender for Endpoint. Ce composant analyse en temps réel le comportement du système pour bloquer l'exécution de codes malveillants. Si une machine présente des signes d'infection critique, l'équipe informatique applique immédiatement le playbook de sécurité consistant à isoler logiquement l'hôte réseau via la console cloud. Le poste est coupé instantanément de tout lien avec la zone serveurs et le réseau DFS pour empêcher la destruction des fichiers partagés, tout en restant connecté à l'équipe IT pour désinfection à distance.

Cycle de vie des matériels : Traitement des DEEE et effacement sécurisé

Le déclassement des matériels obsolètes ou en panne intègre un protocole d'effacement de données strict afin d'éviter toute violation de données résiduelles lors de l'envoi dans la filière de recyclage des déchets électroniques :

- Matériels fonctionnels : Tout support de stockage réformé mais en état de marche fait l'objet d'un effacement logique bas niveau durci via un algorithme d'écriture de passes multiples, rendant impossible toute reconstruction des anciens fichiers.
- Matériels défectueux : Si le support est en panne physique, le service informatique procède à sa destruction physique irréversible au sein des ateliers de la mairie, détruisant définitivement les puces de mémoire flash ou les plateaux.

- Traçabilité GLPI : Chaque opération donne lieu à l'édition d'un certificat de destruction de données, numérisé et rattaché à la fiche de l'actif informatique au sein de la plateforme GLPI, garantissant la conformité de la mairie lors des contrôles de la CNIL.

4. Exercice des droits des personnes et procédure en cas de violation

Exercice des droits des administrés : Articles 15 à 22

Chaque citoyen de la commune dispose d'un droit d'accès, de rectification, de limitation, d'effacement et d'opposition concernant ses informations personnelles stockées par la mairie. Les demandes sont centralisées par le Délégué à la Protection des Données de la collectivité généralement mutualisé auprès du Centre de Gestion de la fonction publique territoriale. Sur instruction écrite du DPO, la DSI exécute l'extraction ou la modification des données dans le délai légal maximal de 30 jours.

Procédure technique d'urgence en cas de violation de données : article 33

En cas d'incident de sécurité majeur entraînant un accès frauduleux, une fuite ou une destruction de données nominatives (cyberattaque par rançongiciel, intrusion physique dans la salle serveur, perte de support), le Responsable IT applique strictement la procédure suivante :

- Confinement immédiat : Coupure des liaisons réseau de la machine compromise via l'EDR Defender, activation du PCA et bascule en mode dégradé sécurisé.
- Recensement des impacts : Évaluation de la nature de la faille, du volume de données impactées compromises au sein du registre interne des violations de données.
- Notification CNIL sous 72 heures : Le DPO de la mairie télécharge et transmet officiellement le rapport de notification d'incident de sécurité auprès des services de la CNIL dans un délai maximal de 72 heures après la découverte de la violation.
- Information des citoyens (Article 34) : Si la violation engendre un risque élevé pour les droits et les libertés des administrés (ex : exfiltration de coordonnées bancaires ou de documents d'identité), la mairie procède à une notification individuelle immédiate de chaque personne impactée.

5. Gestion des sous-traitants et tiers : Article 28 du RGPD

La Mairie de Kernelac s'assure que l'ensemble de ses prestataires techniques et de ses tiers d'infrastructure présente des garanties suffisantes quant à la mise en œuvre de mesures de sécurité conformes au RGPD. Des clauses d'accord de traitement de données et des engagements de confidentialité sont annexés aux contrats :

- Société Volteia Systems : Le prestataire externe est soumis au secret professionnel concernant ses interventions de maintenance de niveau 3. L'intégralité de ses flux d'administration distante fait l'objet d'une journalisation technique immuable sur le serveur de logs de la mairie.

- Société Wasabi : La solution cloud externalisée de rétention des sauvegardes immuables est certifiée ISO 27001. L'activation de la fonction verrouillage d'objets garantit qu'aucune donnée de sauvegarde de la mairie ne peut être modifiée, chiffrée par un tiers malveillant ou supprimée prématurément avant l'échéance de la politique de rétention, assurant la résilience totale de la collectivité.